

Lab 09 – Regulatory Gap Analysis – Solutions

Industrial Security (Bachelor)

• Maps to Section 09

• 60 min

LAB 09

🎯 Goal

Lecturer / TA reference: regulatory mapping for a German water utility, sample gap analysis, grading rubric. Numbers (CAPEX, OPEX, headcount) are indicative orders of magnitude, not procurement quotes.

✅ Step 1 – Regulatory surface (model answer)

- **NIS2** – Directive (EU) 2022/2555. Drinking-water supply is an Annex I *essential entity* sector. Transposition deadline was 17 Oct 2024; the German law (NIS2UmsuCG) governs the duties directly.
- **KRITIS** – BSI-Kritisverordnung (BSI-KritisV). The drinking-water threshold is 500 000 supplied persons; 600k crosses it, so the utility *is* KRITIS-regulated and bound by § 8a BSIG.
- **NIS2UmsuCG** – the German NIS2 transposition act, superseding IT-SiG 2.0 for NIS2 duties (registration, incident reporting, governance accountability).
- **B3S Wasser/Abwasser** – the sectoral security standard (*branchenspezifischer Sicherheitsstandard*) recognised under § 8a BSIG; treated as the de-facto control baseline for the audit.
- **CRA** – Regulation (EU) 2024/2847. Applies whenever the utility procures a connected product (PLC, HMI, sensor, gateway) placed on the EU market; pushes vendor-side security duties.
- **DSGVO** – applies to customer billing and contact PII, but *not* to OT process data unless it can be linked to a natural person.

✓ Steps 2 + 3 – Five obligations, status, 62443 / CSF mapping

Obligation	Status	Justification	IEC 62443	NIST CSF
Incident reporting 24h / 72h / 1 mo (NIS2 Art. 23)	Partial	IT incident process exists; not OT-tuned, no early-warning template.	62443-2-1 SR 6.1	RS.CO-2
Attack-detection capability (§ 8a Abs. 1a BSIG)	Non-compliant	No passive ICS IDS on the OT segment; logs not centralised.	62443-3-3 SR 6.2	DE.CM-1
Asset inventory (B3S; complete OT inventory)	Partial	Corporate CMDB current; OT inventory is a 2019 spreadsheet.	62443-2-1 SR 2.1	ID.AM-1
Patch / vulnerability management for ICS components	Non-compliant	Vendor lifecycles + 24/7 operations preclude routine patching; no compensating-control register.	62443-2-1 SR 2.4	PR.IP-12
Secure remote access for vendors	Partial	Flat site-to-site VPN, shared account, no session recording.	62443-3-3 SR 1.13, SR 2.1	PR.AC-3

✓ Step 4 – Three recommendations (cost / time / owner)

1. **Passive ICS IDS + OT-aware SIEM tier.** Deploy Claroty CTD or Nozomi Guardian on SPAN ports of the process LAN; forward alerts into the existing SIEM. *CAPEX* EUR 80–150 k, *OPEX* EUR 15–25 k/yr, *time* 3–6 months, *owner* CISO + OT lead. Closes the § 8a Abs. 1a gap and feeds DE.CM-1 / DE.AE-3.
2. **Brokered jump host for vendor access.** Replace the flat vendor VPN with a session broker (Cyolo, BeyondTrust PRA, or an audited open-source variant) enforcing MFA and full session recording. *Cost* EUR 30–60 k, *time* 2–3 months, *owner* IT-Security with plant-manager sign-off. Closes SR 1.13 / SR 2.1 / PR.AC-3.
3. **Asset-inventory baseline.** Use the new IDS's passive discovery to enumerate the OT estate, reconcile against the CMDB, and formalise a quarterly reconciliation procedure. *Effort only* (approx. 0.3 FTE for one month), *owner* OT engineering team. Closes ID.AM-1 / SR 2.1 and is a prerequisite for any meaningful patch-management plan.

✓ Common student mistakes

- Treating all *essential-entity* obligations as IT-only obligations. NIS2 cyber-hygiene duties (Art. 21) apply equally to OT.
- Citing DSGVO as applicable to OT process data. It only bites where personal data is involved (billing, customer portal).
- Recommending “patch everything within 30 days” without acknowledging vendor lifecycles, validated firmware images, or maintenance windows.
- Confusing the 500 k KRITIS threshold with the NIS2 size cap – NIS2 applies regardless of headcount for essential-entity sectors.
- Forgetting CRA on the procurement side: even a fully compliant operator inherits risk from non-CRA-conformant products.

 Grading rubric

Total 20 points.

- **Step 1 – Regulatory surface (5 pt).** 1 pt each for NIS2, KRITIS/BSIG, NIS2UmsuCG, B3S, CRA. Miss DSGVO scope nuance: −1.
- **Step 2 – Five obligations (5 pt).** 1 pt each, requires concrete obligation *and* defensible status verdict.
- **Step 3 – IEC 62443 + CSF mapping (5 pt).** 0.5 pt per correct SR, 0.5 pt per correct CSF subcategory across the five rows.
- **Step 4 – Three recommendations (5 pt).** 1 pt per recommendation for technical fit, 1 pt per recommendation for plausible cost/time/owner triple; cap at 5 pt.

Penalties: invented regulation identifiers −2; “patch everything” without OT caveat −1; recommendation without owner −0.5 each.